AUTHENTICATION AND ACCOUNT MANAGEMENT

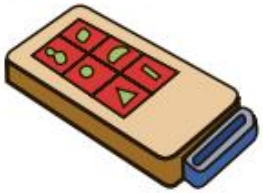
Ali Mazloum

Authentication Credentials

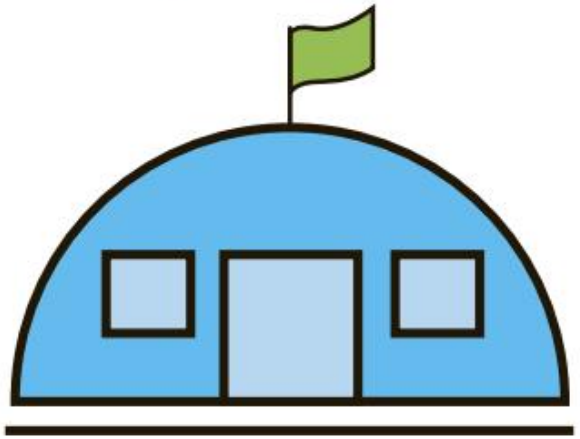
- Types of authentication credentials
- Where you are
  - Example: a military base
- What you have
  - Example: key fob to lock your car
- What you are
  - Example: facial characteristics recognized
- What you know
  - Example: combination to health club locker
- What you do
  - Example: do something to prove authenticity

Authentication Credentials

Key fob (what he has)



Military base (where he is)



Facial characteristics (what he is)

Combination lock (what he knows)

Pushups (what he does)

WHAT YOU KNOW: PASSWORDS

What You Know: Passwords

- User logging in to a system
  - Asked to identify himself
    - User enters username
  - User asked to authenticate
    - User enters password
- Passwords are the most common type of authentication today
- Passwords provide only weak protection
  - Actions can be taken to strengthen passwords

Password Weaknesses (1)

- Weakness of passwords is linked to human memory
  - Humans can memorize only a limited number of items
- Long, complex passwords are most effective
  - Most difficult to memorize
- Users must remember passwords for many different accounts
- Each account password should be unique
- Security policies mandate passwords must expire
  - Users must repeatedly memorize passwords

Password Weaknesses (2)

- Users often take shortcuts
  - Using a weak password
  - Examples: common words, short password, or personal information
- When attempting to create stronger passwords, they generally follow predictable patterns:
  - Appending: using letters, numbers, and punctuation in a pattern
  - Replacing: users use replacements in predictable patterns

Password Weaknesses (3)

Table 11-1 Ten most common passwords

Rank	Password
1	123456
2	123456789
3	abc123
4	password
5	password1
6	12345678
7	111111
8	1234567
9	12345
10	1234567890

Attacks on Passwords

- Attacks that can be used to discover passwords:
  - Social engineering
    - Phishing, shoulder surfing, dumpster diving
- Capturing
  - Keylogger, protocol analyzer
  - Man-in-the-middle and replay attacks
- Resetting
  - Attacker gains physical access to computer and resets password

Attacks on Passwords

- Offline attack
  - Method used by most password attacks today
  - Attackers steal file of password digests
    - Compare with their own digests they have created
- Offline password attacks include:
  - Brute force
  - Mask
  - Rule
  - Dictionary
  - Rainbow tables
  - Password collectionsa

Brute Force

- Every possible combination of letters, numbers, and characters used to create encrypted passwords and matched against stolen file
- Slowest, most thorough method
- NTLM (New Technology LAN Manager) hash
  - An attacker who can steal the digest of an NTLM password would not need to try to break it
  - He would simply pretend to be the user and send that hash to the remote system to then be authenticated
  - Known as a pass the hash attack

Mask Attack

- Mask Attack
  - A more targeted brute force attack that uses placeholders for characters in certain positions of the password
  - Parameters that can be entered in a mask attack include:
    - Password length
    - Character set
    - Language
    - Pattern
    - Skips
- Rule Attack
  - Conducts a statistical analysis on the stolen passwords that is used to create a mask to break the largest number of passwords

Rule and Mask Attack

```
[*] Length Statistics...
[+]                          8: 62% (612522)
[+]                          6: 18% (183307)
[+]                          7: 14% (146152)
[+]                          5: 02% (26438)
[+]                          4: 01% (15088)
[+]                          3: 00% (2497)
[+]                          2: 00% (308)
[+]                          1: 00% (113)

[*] Charset statistics...
[+]              loweralphanum: 47% (470580)
[+]                 loweralpha: 46% (459208)
[+]                    numeric: 05% (56637)
```

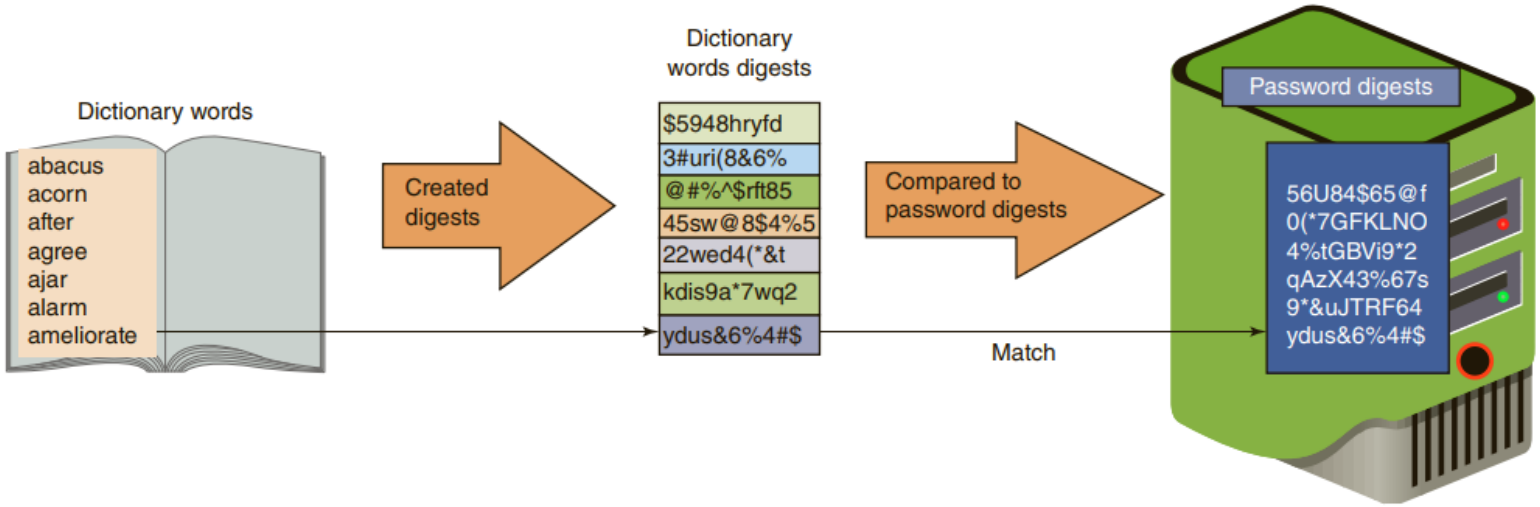
Figure 11-2 Rule attack statistical analysis

```
[*] Advanced Mask statistics...
[+]          ?l?l?l?l?l?l?l?l: 04% (688053)
[+]              ?l?l?l?l?l?l: 04% (601257)
[+]            ?l?l?l?l?l?l?l: 04% (585093)
[+]        ?l?l?l?l?l?l?l?l?l: 03% (516862)
[+]            ?d?d?d?d?d?d?d: 03% (487437)
[+]      ?d?d?d?d?d?d?d?d?d?d: 03% (478224)
[+]          ?d?d?d?d?d?d?d?d: 02% (428306)
[+]          ?l?l?l?l?l?l?d?d: 02% (420326)
[+]      ?l?l?l?l?l?l?l?l?l?l: 02% (416961)
[+]              ?d?d?d?d?d?d: 02% (390546)
[+]        ?d?d?d?d?d?d?d?d?d: 02% (307540)
[+]            ?l?l?l?l?l?d?d: 02% (292318)
[+]        ?l?l?l?l?l?l?l?d?d: 01% (273640)
```

Figure 11-3 Rule attack generated masks

Dictionary Attacks

- Attacker creates digests of common dictionary words
- Compares against stolen digest file
- Pre-image attack - a dictionary attack that uses a set of dictionary words and compares it with the stolen digests
- Birthday attack - the search for any two digests that are the same



Rainbow Tables

- A rainbow table is an efficient way to store data that has been computed in advance to facilitate cracking passwords
- Unlike brute force attack, which works by calculating the hash function of every string, a rainbow table already computes hashes of the large set of available strings

Plaintext	MD5 Checksum
123456	e10adc3949ba59abbe56e057f20f883e
123456789	25f9e794323b453885f5181f1b624d0b
password	5f4dcc3b5aa765d61d8327deb882cf99
adobe123	7558af202997483d3afef3bb2b5a709d
12345678	25d55ad283aa400af464c76d713c07ad
qwerty	d8578edf8458ce06fbc5bb76a58c5ca4
1234567	fcea920f7412b5da7be0cf42b8c93759
111111	96e79218965eb72c92a549dd5a330112
photoshop	c7c9cfbb7ed7d1cebb7a4442dc30877f
123123	4297f44b13955235245b2497399d7a93

Password Collection

- In 2009, an attacker used an SQL injection attack, and more than 32 million user passwords (in cleartext) were stolen
- These passwords provided two key elements for password attacks:
  - Gave attackers a large corpus of real-world passwords
  - Have provided attackers advanced insight into the strategic thinking of how users create passwords

> Back in 2009, threat actors hacked into the website servers of social app RockYou, accessing over 32 million user passwords stored in plaintext. Now, in what appears to be the largest data breach in history, attackers have compromised 262 times as many passwords. With 3.2 billion leaked passwords from multiple databases, this attack has been dubbed RockYou2021.

Password Security

- Securing passwords from attacks depends upon the user as well as the enterprise
  - For the user
    - It involves properly managing passwords
  - For the enterprise
    - It involves protecting password digests

Password Security

- Managing Passwords
  - Most critical factor in a strong password is **length**
  - In addition to having long passwords, other recommendations are:
    - **Do not** use passwords that consist of **dictionary words** or phonetic words
    - Do **not repeat characters** or use sequences
    - Do not use birthdays, family member names, pet names, addresses or any personal information
- Also, use **non-keyboard characters**
  - Created by holding down the ALT key while typing a number on the numeric keypad

Password Security

Table 11-3 Number of possible passwords

Keyboard keys	Password length	Number of possible passwords	Average attempts to break password
95	2	9025	4513
95	3	857,375	428,688
95	4	81,450,625	40,725,313
95	5	7,737,809,375	3,868,904,688
95	6	735,091,890,625	367,545,945,313

Recommendations for Enterprises

- Use a strong random number generator to create a salt of at least 128 bits
- Input the salt and the user's plaintext password into the PBKDF2 algorithm that is using HMAC-SHA—256 as the core hash
- Perform at least 30,000 iterations on PBKDF2
- Capture the first 256 bits of output from PBKDF2 as the password digest
- Store the iteration count, the salt, and the password digest in a secure password database

WHAT YOU HAVE

What you have

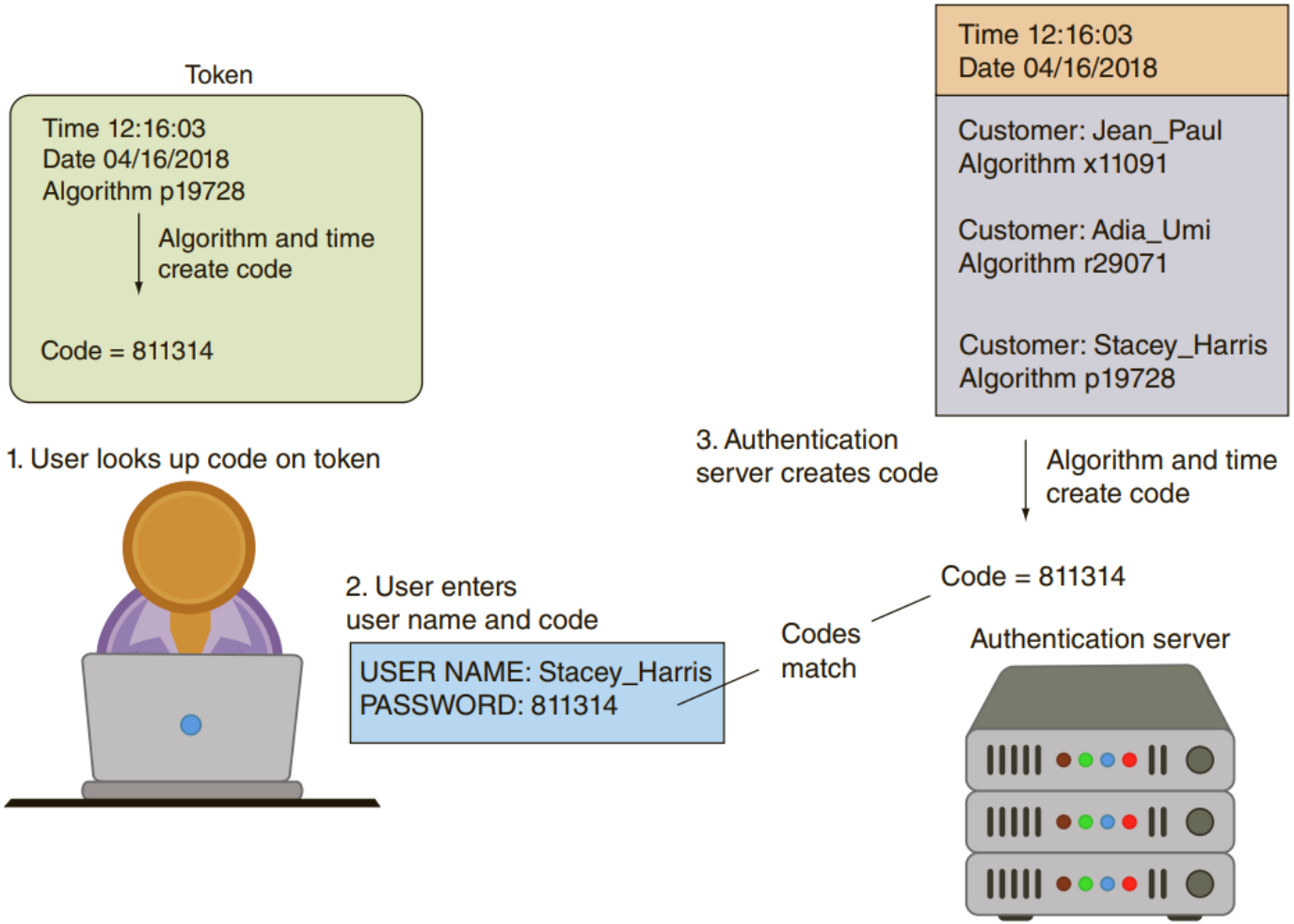
- Multifactor authentication
  - When a user is using more than one type of authentication credential
  - Example: what a user knows and what a user has could be used together for authentication
- Single-factor authentication
  - Using just one type of authentication
- Most common items used for authentication:
  - Tokens, cards, and cell phones

What you have

- Tokens
  - Used to create a one-time password (OTP)
    - Authentication code that can be used only once or for a limited period of time
  - Hardware security token
    - Typically a small device with a window display
  - Software security token
    - Stored on a general-purpose device like a laptop computer or smartphone
- Time-based one-time password (TOTP)
  - Synched with an authentication server
  - Code is generated from an algorithm
  - Code changes every 30 to 60 seconds

Figure 11-6 Hardware security token

Time-based one-time password (TOTP)

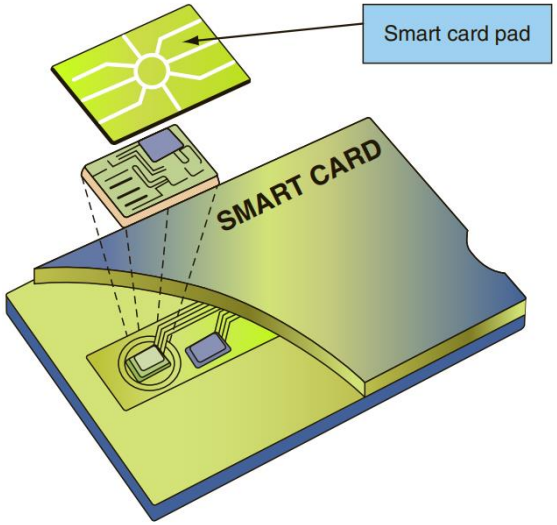


Advantages over Passwords

- Token code changes frequently
- Attacker would have to crack code within time limit
- User may not know if password has been stolen
- If token is stolen, it becomes obvious, and steps could be taken to disable account

Cards

- A smart card contains an **integrated circuit chip** that can hold information
- The information can be used as part of the authentication process
- A common access card (CAC) is a U.S. Department of Defense (DoD) smart card that is used for identification
- Take advantage of certificate-based authentication



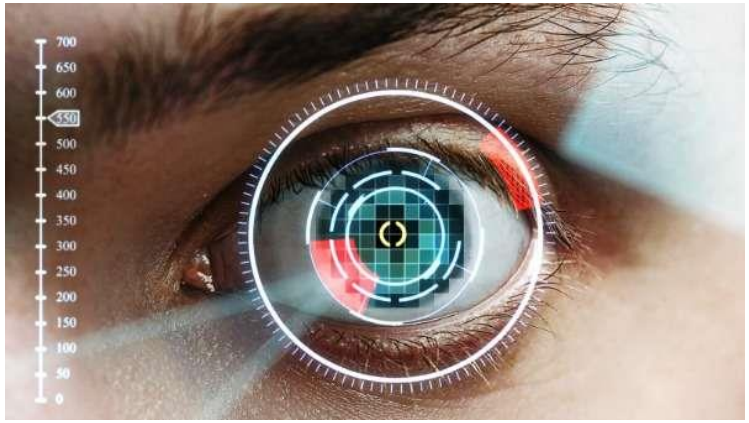
Cell Phones

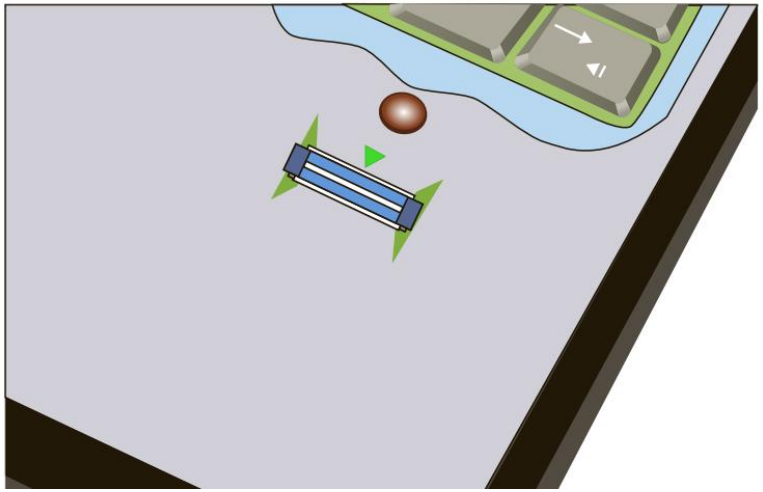
- Tokens and cards are increasingly being replaced today with cell phones
- A code can be sent to a user's cell phone through:
  - Software security token app on the device
  - Text message
  - Phone call
- Example is DUO

WHAT YOU ARE

Standard Biometrics

- Standard biometrics uses a person's unique physical characteristics for authentication
  - Face
  - Hands
  - Eyes
- Specialized Biometric Scanners
  - dedicated biometric scanners
  - A retinal scanner uses the human retina as a biometric identifier
  - A fingerprint scanner, which uses a fingerprint as a biometric identifier





Standard Biometrics

- Standard Input Devices
  - Can use standard computer input devices for recognition, such as a microphone or camera
- Voice recognition
  - Using a standard computer microphone, can be used to authenticate users based on the unique characteristics of a person's voice
  - An attacker could record the user's voice and then create a recording to use for authentication
- Iris scanner
  - Use a standard computer webcam
- Facial recognition

Biometric Disadvantages

- Standard biometrics has three disadvantages

1. The **cost** for fingerprint and retinal identification that requires specialized biometric scanners
2. Biometric authentication is not **foolproof**:
   - Genuine users may be rejected while imposters are accepted
   - The false acceptance rate (FAR) or false positive is the frequency at which imposters are accepted as genuine
   - The false rejection rate (FRR) or false negative is the frequency that legitimate users are rejected
   - Biometric systems are tuned so that the FAR and FRR are equal over the size of the population
3. Biometric systems can be “tricked.”
   1. Pictures of an iris can fool an iris recognition system
   2. Fingerprints can be collected from water glasses and used to trick fingerprint readers

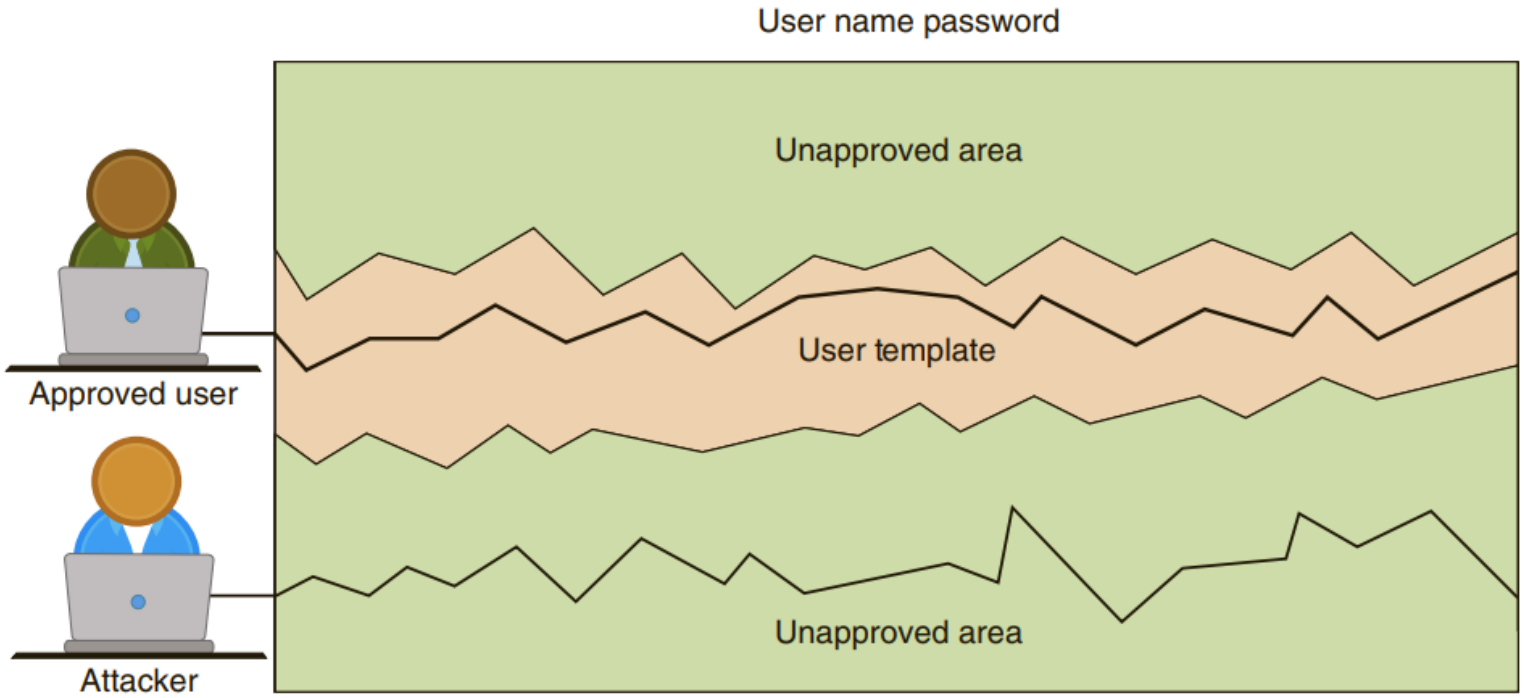
WHAT YOU DO

What You Do: Behavioral Biometrics

- Another type of authentication is based on actions that the user is uniquely qualified to perform
- **Keystroke dynamics** attempts to recognize a user's unique typing rhythm
- A study funded by the U.S. National Bureau of Standards concluded that the keystroke dynamics of entering a user name and password could provide up to **98 percent accuracy**

What You Do: Behavioral Biometrics

- Keystroke dynamics uses two unique typing variables
  1. **Dwell time**, which is the time it takes for a key to be pressed and then released
  2. **Flight time**, or the time between keystrokes



WHERE YOU ARE

Where You Are: Geolocation

- Where the user is located, known as geolocation
- Most often used to reject imposters instead of accepting authorized users
- Where does Alice normally access her bank's website?
- If it is typically from her home computer on nights and weekends, then this information can be used to establish a geolocation pattern based on the IP of Alice
- If a computer located in China suddenly attempts to access her bank's website, this might be an indication that an attacker instead of Alice is at work